

Gestión de activos de información y análisis de riesgos en seguridad de la información

Breve descripción:

Este componente formativo se centra en la gestión de activos de información y el análisis de riesgos, considerados elementos esenciales para el control de la seguridad en las organizaciones. Mediante la identificación, clasificación y valoración de los activos, se fortalece la comprensión de su relevancia estratégica y de las vulnerabilidades asociadas. Además, se promueve la detección de amenazas y la aplicación de metodologías para la evaluación de riesgos, integrando procedimientos técnicos con marcos de referencia nacionales e internacionales. De este modo, el aprendiz adquiere competencias para implementar controles adecuados, alineados con las necesidades de la organización, y fomenta una cultura de seguridad integral, basada en la reflexión y la aplicación práctica en el contexto productivo.

Tabla de contenido

Introducción.....	1
1. Activos de información.....	4
1.1 Tipologías de activos	5
1.2 Procedimientos para su registro y valoración	8
2. Seguridad de la información.....	16
2.1 Principio de confidencialidad.....	16
2.2 Principio de integridad	17
2.3 Principio de disponibilidad	19
3. Gestión de riesgos de la información.....	21
3.1 Criterios de identificación.....	22
3.2 Análisis de riesgos	23
3.3 Valoración y priorización de riesgos.....	25
Síntesis.....	32
Material complementario.....	33
Glosario.....	35
Referencias bibliográficas.....	37
Créditos.....	38

Introducción

En la actualidad, las organizaciones dependen cada vez más de la información como un recurso estratégico que respalda la toma de decisiones, garantiza la continuidad de los procesos y genera valor. Sin embargo, el avance de las tecnologías digitales ha incrementado la exposición a riesgos y amenazas que pueden comprometer los datos, los sistemas y, en consecuencia, la estabilidad institucional. Por ello, resulta indispensable establecer mecanismos sólidos de control de la seguridad de la información, que protejan los activos críticos y aseguren el cumplimiento de los objetivos organizacionales.

Este componente formativo tiene como propósito proporcionar a los aprendices los conocimientos y competencias necesarios para identificar y clasificar los activos de información, comprender los principios fundamentales de la seguridad y aplicar metodologías de gestión de riesgos. Estos elementos constituyen la base para diseñar e implementar estrategias de protección acordes con la realidad de cada organización y alineadas con estándares internacionales.

La formación se desarrollará mediante un enfoque práctico y aplicado, que combina el análisis de casos, la elaboración de registros e inventarios de activos y el diseño de matrices de riesgo. De este modo, los aprendices no solo adquirirán comprensión teórica, sino que también podrán transferir los conocimientos al contexto empresarial, contribuyendo activamente al fortalecimiento de la seguridad de la información y a la construcción de entornos más confiables.

Video 1. Gestión de activos de información y análisis de riesgos en seguridad de la información



[Enlace de reproducción del video](#)

Síntesis del video: Gestión de activos de información y análisis de riesgos en seguridad de la información

En la actualidad, la información es el recurso más valioso de una organización. De ella dependen las decisiones, la continuidad y el valor institucional. Pero con el avance digital, también crecen los riesgos y amenazas que pueden comprometerla. Por eso, gestionar los activos de información y analizar los riesgos es esencial. Los controles de seguridad protegen los datos críticos y garantizan los objetivos organizacionales. Este componente formativo fortalece las competencias para identificar, clasificar y valorar activos, comprender los principios de seguridad y aplicar metodologías de gestión de riesgos. A través de un enfoque práctico, se

trabajaré con casos reales, registros e inventarios, permitiendo transferir el aprendizaje al entorno empresarial. En síntesis, proteger la información es cuidar el corazón de la organización. Este proceso te prepara para diseñar estrategias seguras y confiables, alineadas con estándares internacionales de seguridad de la información.

1. Activos de información

Hoy en día, la información se considera uno de los recursos de mayor valor dentro de una organización, ya que sobre ella se toman decisiones, se diseñan estrategias y se garantiza la continuidad de los procesos. Por esta razón, la información se reconoce como un activo, ya sea tangible o intangible, capaz de generar conocimiento, respaldar procesos y contribuir al logro de los objetivos organizacionales. Dado su valor, requiere un tratamiento especial para evitar alteraciones, pérdidas o usos indebidos que podrían ocasionar daños económicos, legales o reputacionales, afectando gravemente a la empresa.

Según la **Agencia Nacional Digital (AND) de Colombia**, un activo de información es todo recurso que tiene valor para la organización y que está relacionado con el ciclo de vida de la información, ya sea porque la contiene, la genera, la procesa, la almacena o la gestiona (AND, 2020a).

La norma ISO/IEC 27001 amplía esta definición, indicando que un activo de información no se limita únicamente a los datos digitales. También incluye:

- **Elementos físicos**
Infraestructura tecnológica o arquitectónica.
- **Elementos lógicos**
Bases de datos, software y aplicaciones.
- **Elementos humanos**
Usuarios y su conocimiento.
- **Elementos intangibles**
Reputación, marca o propiedad intelectual.

Dado el valor que cada activo puede representar para la organización, es fundamental **identificarlos, clasificarlos y valorarlos** dentro de un sistema de gestión de seguridad de la información. Esto permite aplicar **controles que garanticen su confidencialidad, integridad y disponibilidad**, protegiéndolos frente a riesgos.

Con el tiempo, las organizaciones comenzaron a considerar la información no solo desde una perspectiva operativa, sino también estratégica. Hoy, elementos como correos electrónicos, políticas internas, manuales de procesos, bases de datos e incluso la experiencia de los trabajadores se han convertido en **activos críticos** que deben protegerse para asegurar la continuidad del negocio y mantener la confianza de los interesados.

1.1 Tipologías de activos

Los activos de información pueden ser presentados de diferentes formas en una organización, por lo tanto, una buena clasificación ayuda en la gestión y protección de los mismos. Reconocer su tipología permite saber y entender que hay que proteger, cómo se deben controlar, y qué valor estratégico aportan a los procesos; lo que facilita su identificación, protección y gestión adecuada dentro de la empresa.

En la gestión de la seguridad de la información, los activos de información pueden ser clasificados desde diferentes perspectivas, de tal manera que se facilite su administración y protección; por ejemplo: según su naturaleza o función.

En este caso, se tomará de base la clasificación con la cual trabaja la AND (AND, 2020b), la cual se explica a continuación:

- **Activos de información**

Es todo dato, documento, registro o conocimiento que posee valor para la organización, ya sea en formato físico o digital. Estos activos incluyen bases de datos, reportes, manuales, correspondencia oficial, entre otros. Algunos tienden a confundirlo con los activos organizacionales, por eso hay que tener en cuenta que su diferencia radica en que este activo se centra en el contenido informativo que respalda decisiones y operaciones, no en la estructura o el sistema que lo gestiona.

- **Activos tecnológicos y/o digitales**

Son todos los dispositivos tecnológicos que soportan el trabajo y la gestión de la información y las demás operaciones de la empresa. Dentro de estas se encuentra el hardware, el software, las redes de comunicación y plataformas digitales como intranet, VPN o servicios FTP, páginas web entre otras.

- **Activos de infraestructura física**

Es toda la parte física de la empresa, desde sus instalaciones mismas, oficinas, hasta redes eléctricas y demás recursos materiales que sirven de soporte físico para que se realicen los procesos que permiten el desarrollo y continuidad del negocio.

- **Activos organizacionales**

Es el conjunto de procesos, metodologías, políticas, procedimientos, y servicios de la empresa, que permiten la ejecución ordenada y eficiente de todas las actividades que se desarrollan dentro de la organización, como la visión, la misión, la normativa y los modelos de gestión, entre otros. A diferencia del activo de información, no se enfoca en los datos o

contenidos específicos, sino en el marco institucional y administrativo que orienta el funcionamiento de la organización.

- **Activos de recursos humanos**

Lo conforman las personas que están vinculadas a la empresa, ya sea de manera temporal o permanente, como los empleados de planta y los contratistas. Representan un activo clave por sus conocimientos, habilidades, experiencias, responsabilidades, cargos y funciones que desempeñan dentro de la empresa, lo cual influye directamente en la continuidad y seguridad de los procesos.

Para entender mejor cómo se identifican y clasifican los activos de información en diferentes contextos, a continuación se presentan ejemplos aplicados en tres tipos de organizaciones, relacionando los activos relevantes asociados a la gestión de una institución prestadora de salud, una corporación educativa y una finca agropecuaria:

Tabla 1. Ejemplos de activos en PYMES

Tipología	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
Activos de información	Historias clínicas electrónicas, consentimientos informados digitalizados, reportes epidemiológicos enviados al Ministerio de Salud, nómina de empleados.	Bases de datos académicas (calificaciones, matrículas), actas de consejo académico, repositorios de investigación, información de egresados.	Registros de vacunación de ganado, certificados de calidad, contratos de venta agrícola, facturación electrónica.
Activos tecnológicos y/o digitales	HIS (Hospital Information System), PACS para imágenes diagnósticas, firewalls	LMS (Moodle), sistema académico (SIA), servidores para aulas virtuales, software	Software ERP agropecuario, sensores IoT de humedad, GPS en tractores, drones

Tipología	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
	médicos, tablets para registro en cama de hospitalización.	antiplagio, sistema de backup institucional.	para fumigación, sistema de respaldo en la nube.
Activos de infraestructura física	Centros de datos clínicos, consultorios con red eléctrica redundante, salas de cirugía, cámaras de videovigilancia internas.	Centros de datos, laboratorios de física y química, biblioteca física, cableado estructurado de red, sistema contra incendios.	Bodegas de almacenamiento de fertilizantes, tanques de agua, corrales certificados, sistemas de riego presurizado, cercas de seguridad perimetral.
Activos organizacionales	Protocolos de atención en urgencias, plan de continuidad de negocio hospitalario, acuerdos de confidencialidad con proveedores de TI, convenios con EPS.	Reglamento estudiantil, plan de calidad educativa, manual de convivencia, política institucional de uso de TIC, convenios con universidades extranjeras.	Plan de Buenas Prácticas Agrícolas (BPA), normas de bioseguridad, contratos con proveedores, plan de gestión de residuos agroindustriales.
Activos de recursos humanos	Médicos especialistas, personal de urgencias, técnicos de laboratorio clínico, personal de seguridad hospitalaria, proveedores externos de esterilización.	Docentes de planta y cátedra, personal de biblioteca, coordinadores de sistemas, contratistas de mantenimiento tecnológico.	Ingeniero agrónomo, veterinarios, trabajadores de campo, personal administrativo, operadores de maquinaria agrícola.

1.2 Procedimientos para su registro y valoración

El registro y la valoración de activos de información son procedimientos complementarios y fundamentales para la gestión de la seguridad de la información en una organización. El registro permite identificar, documentar y mantener actualizada la información sobre los activos que contienen, procesan o respaldan datos relevantes para la actividad comercial, incluyendo su ubicación, responsables de uso y

administración, así como su valor para la organización. A partir de este conocimiento, la valoración busca determinar la importancia o criticidad de cada activo, estableciendo prioridades para su protección y gestión. Esta valoración se basa en el análisis del impacto que podría generar la pérdida, alteración o divulgación no autorizada de la información, considerando los tres principios esenciales de la seguridad: confidencialidad, integridad y disponibilidad.

La ISO/IEC 27001:2022, en el control A.5.9 (Gestión de inventario de la información y otros activos asociados), establece que toda organización debe contar con un inventario actualizado de activos de información, debidamente documentado y vinculado a los procesos de negocio (Cane, 2025).

A continuación, se presentan una serie de pasos para registrar y valorar los activos de información, aunque estos procedimientos pueden realizarse de manera conjunta o separada, según lo determine cada organización:

1. Identificación del activo

Asignar un nombre claro y único al activo de información. Ubicarlo dentro de una categoría general o tipología.

2. Descripción del activo

Incluir una breve explicación que permita comprender de qué se trata y cuál es su función dentro de la empresa.

3. Asignación de responsable

Definir la persona, área o dependencia responsable del activo. Registrar también un custodio que administre operativamente. Esto asegura trazabilidad y claridad de responsabilidades.

4. Ubicación del activo

Especificar la localización física (ejemplo: sala de servidores, archivo central) o lógica (ejemplo: nube, repositorio digital).

5. Usuarios asociados

Identificar quiénes hacen uso del activo (roles, áreas o perfiles). Ejemplo: área contable y área de auditoría interna.

6. Relaciones con otros activos

Documentar dependencias o vínculos con otros activos. Ejemplo: el sistema de facturación depende del servidor de base de datos.

7. Registro en formato oficial

Consolidar toda la información en una plantilla estandarizada. Se puede usar como referencia el formato del MINTIC (2025), ajustándolo según las necesidades de la organización.

8. Campos para el registro

- ✓ **Código o identificador único:** diferencia cada activo, evita duplicidad y pérdida de trazabilidad.
- ✓ **Nombre del activo:** referencia rápida para entender de qué se trata.
- ✓ **Descripción breve:** aclara alcance y uso del activo.
- ✓ **Tipo de activo:** clasificación básica (información, software, hardware, servicios).
- ✓ **Ubicación:** física o lógica, clave para recuperación y auditorías.
- ✓ **Propietario del activo:** persona o área responsable de uso, custodia y actualización.
- ✓ **Área usuaria / dependencias:** quién hace uso del activo y su impacto organizacional.

- ✓ **Fecha de registro o última actualización:** mantiene el inventario vigente y evita obsolescencia.

Dado que pueden presentarse confusiones al momento de clasificar los activos dentro de determinadas tipologías o categorías, ya que estas pueden variar según la referencia utilizada, en la siguiente tabla se presenta una equivalencia que sirve como guía. De esta manera, se ofrecen bases para ubicar los activos de manera adecuada o, en su defecto, realizar los ajustes necesarios cuando se trabaje con tipologías que presenten diferencias:

Tabla 2. Equivalencia de tipologías de activos de información

AND (Agencia Nacional Digital de Colombia)	MINTIC (Ministerio de Tecnologías de la Información y las Comunicaciones)	ISO/IEC 27001 (Mohan, 2024)	MAGERIT v3 (MINHAP, 2012)
Activos de información.	Información.	Información.	Información o datos, soportes de información.
Activos tecnológicos y/o digitales.	Software, hardware.	Software, hardware, servicios.	Software, aplicaciones, equipos informáticos, redes de comunicación.
Activos de infraestructura física.	Equipamiento auxiliar, soporte.	Oficinas.	Equipamiento auxiliar, instalaciones.
Activos organizacionales.	Procesos.	Activos intangibles.	Servicios.
Activos de recursos humanos.	Recurso humano, otros.	Personas.	Personal.

Después de tener el registro, se realiza una valoración de los activos de información, determinando qué tan importante son y qué impacto tendría para la

empresa el perderlos, dañarlos o que sean revisados por personas no autorizadas. Con la valoración también se busca responder preguntas como las siguientes:

- ¿Qué tan valioso es el activo para la empresa?
- ¿Qué tan vulnerable es el activo?
- ¿Qué nivel de protección necesita?

A continuación, los factores de análisis en la valoración de activos de información:

- **Confidencialidad**

Evalúa qué tan grave sería que la información del activo se haga pública o caiga en manos equivocadas. Ejemplo: datos financieros, historias clínicas.

- **Integridad**

Determina el impacto si la información se altera, se manipula o pierde precisión. Ejemplo: un informe de inventario puede causar pérdidas económicas.

- **Disponibilidad**

Analiza qué tan crítico es que el activo esté siempre disponible cuando se necesita. Ejemplo: un sistema de pagos de una tienda en línea debe funcionar 24 / 7 todo el año.

Las empresas pueden usar escalas simples para que el proceso de valoración sea más sencillo, tales como:

- **Alta (3 puntos)**

La pérdida o daño podría causar un impacto crítico en la organización.
Ejemplo: caída de un sistema financiero.

- **Media (2 puntos)**

La pérdida o daño podría afectar las operaciones, pero se puede afrontar con alternativas de recuperación.

Ejemplo: base de datos de proveedores.

- **Baja (1 punto)**

La pérdida o daño no afecta significativamente a la empresa.

Ejemplo: documentos de referencia pública.

De esta forma, es posible sumar o promediar los valores obtenidos para priorizar los activos más sensibles o aquellos que podrían verse más impactados, generando mayores consecuencias para la empresa. Asimismo, es importante considerar que se pueden incluir otros parámetros de valoración y que las escalas pueden variar, ya sea aplicando un enfoque cuantitativo o cualitativo. No obstante, este aspecto se abordará con mayor detalle en el apartado correspondiente a la gestión de riesgos de la información.

A continuación, se presenta un ejemplo de registro de activos basado en la IPS ManoSana, utilizada anteriormente para ilustrar otros temas tratados en esta sección:

Tabla 3. Registro de activos de información de la IPS ManoSana

ID	Activo	Tipología	Descripción breve	Propietario o responsable	Ubicación	Fecha / actualización
A - 001.	Historias clínicas electrónicas.	Información.	Base de datos con información sensible de pacientes.	Coordinador de historia clínica.	Servidor principal - Sede central.	31/08/2025.

ID	Activo	Tipología	Descripción breve	Propietario o responsable	Ubicación	Fecha / actualización
A - 002.	Software de gestión hospitalaria (HOSPI-SOFT).	Tecnológicos y/o digitales.	Sistema para citas, facturación y control de pacientes.	Área de sistemas.	Nube privada contratada (AWS).	31/08/2025.
A - 003.	Servidores y equipos de red.	Tecnológicos y/o digitales.	Equipos que soportan el sistema de información y la red interna.	Jefe de tecnología.	Sala de servidores - sede principal.	31/08/2025.
A - 004.	Planta eléctrica de respaldo.	Infraestructura física.	Provee energía en caso de fallas eléctricas.	Área de mantenimiento.	Patio posterior - sede principal.	31/08/2025.
A - 005.	Infraestructura de red física (cableado, switches).	Infraestructura física.	Conectividad de datos en todas las áreas de la IPS.	Área de sistemas.	Toda la sede.	31/08/2025.
A - 006.	Manuales de procedimientos clínicos.	Organizacionales.	Documentación de protocolos médicos y administrativos.	Comité de calidad.	Oficina de Calidad.	31/08/2025.
A - 007.	Políticas de seguridad de la información.	Organizacionales.	Normas internas para el manejo seguro de la información.	Comité de seguridad informática.	Intranet corporativa.	31/08/2025.

ID	Activo	Tipología	Descripción breve	Propietario o responsable	Ubicación	Fecha / actualización
A - 008.	Médicos especialistas.	Recursos humanos.	Profesionales de la salud encargados de atención directa a pacientes.	Coordinador médico.	Consultorios.	31/08/2025.
A - 009.	Personal administrativo.	Recursos humanos.	Personal encargado de procesos de facturación, contabilidad y archivo.	Jefe administrativo.	Oficinas administrativas.	31/08/2025.
A - 010.	Equipo de soporte técnico.	Recursos humanos.	Encargados de mantenimiento y soporte a usuarios.	Jefe de tecnología.	Área de Sistemas.	31/08/2025.

2. Seguridad de la información

Hablar de seguridad de la información implica proteger los activos de información de una organización frente a amenazas que puedan comprometer su confidencialidad, integridad y disponibilidad. Estos tres principios son fundamentales para garantizar la eficiencia y eficacia de los procesos, asegurando que la información sea fiable, precisa y accesible únicamente por quienes están autorizados (Novasep, 2021). La seguridad de la información es un concepto transversal a toda la organización, independientemente del sector, y constituye la base para establecer controles, políticas y procedimientos que aseguren la continuidad operativa y minimicen los riesgos a los que se expone la entidad.

Comprender estos principios es esencial, ya que sobre ellos se sustentan la toma de decisiones, garantizando que estén alineadas con los objetivos estratégicos y la normativa de la organización.

2.1 Principio de confidencialidad

Este principio garantiza que la información y los activos asociados sean accesibles únicamente por las personas autorizadas, evitando divulgaciones, pérdidas o usos indebidos que puedan afectar a la organización o a terceros vinculados a ella. Para preservar la confidencialidad, es necesario aplicar controles de acceso, permisos, cifrado de datos, políticas de manejo de información sensible, así como brindar capacitación al personal para prevenir filtraciones o mal uso de la información.

La relevancia de este principio radica en que:

- Garantiza la privacidad de usuarios y clientes.

- Previene sanciones legales y regulatorias por incumplimiento de normativas.
- Protege la reputación de la organización frente a incidentes de divulgación no autorizada.

Tabla 4. Ejemplos de confidencialidad

Sector	Ejemplos
IPS ManoSana	• Acceso restringido a historias clínicas, informes de laboratorio y resultados de exámenes solo para médicos y enfermeras autorizadas. • Cifrado de comunicaciones electrónicas con laboratorios externos.
Escuela Armando López Sierra	• Restricción de acceso a calificaciones, expedientes de estudiantes y datos de investigación. • Plataforma LMS con control de usuarios y permisos diferenciados por rol.
Finca La Costa	• Acceso controlado a registros de producción, contratos de venta y planes de manejo de cultivos solo para administradores y personal autorizado. • Uso de contraseñas para información almacenada en los sistemas electrónicos y almacenamiento seguro de documentos físicos.

2.2 Principio de integridad

Este principio garantiza que la información y los activos asociados se mantengan exactos, completos y sin alteraciones no autorizadas durante su creación, almacenamiento, transmisión y uso. Para mantener la integridad se tienen que implementar controles que detecten modificaciones indebidas, errores o corrupciones

de datos, asegurando con ello que la información confiable y consistente para la toma de decisiones.

Su importancia consiste en que:

- Previene decisiones incorrectas derivadas de información alterada.
- Protege la reputación de la organización asegurando la veracidad de los datos.
- Facilita el cumplimiento normativo, especialmente en sectores que requieren registros confiables, como salud, educación y producción.

Tabla 5. Ejemplos de integridad

Sector	Ejemplos
IPS ManoSana	• Evitar modificaciones no autorizadas en historias clínicas, resultados de laboratorio y recetas. • Sistemas de auditoría que registran cambios en los expedientes médicos.
Escuela Armando López Sierra	• Control de modificaciones en calificaciones y actas académicas. • Protección de trabajos de investigación contra alteraciones. • Registro de cambios en plataforma LMS con historial de versiones.
Finca La Costa	• Garantizar que los registros de inventario, control de fertilización y planes de cultivo no sean alterados sin autorización. • Sistemas de backup que aseguran la recuperación de datos originales.

2.3 Principio de disponibilidad

Este principio asegura que la información y los activos asociados estén accesibles y puedan ser utilizados cuando los usuarios autorizados lo requieran, garantizando con ello la continuidad de los procesos organizacionales. Para mantener la disponibilidad se tienen que implementar controles que reduzcan los riesgos de interrupciones, fallas técnicas, desastres o ataques que puedan afectar el acceso a los datos.

Su importancia consiste en que:

- Asegura que los procesos críticos de la organización funcionen sin interrupciones.
- Previene pérdidas económicas y operativas derivadas de la indisponibilidad de información o sistemas.
- Garantiza el cumplimiento de compromisos con clientes, estudiantes o usuarios finales.

Tabla 6. Ejemplos de disponibilidad

Sector	Ejemplos
IPS ManoSana	• Sistema de citas y agendas médicas 24 / 7. • Acceso constante a historiales clínicos electrónicos. • Disponibilidad de equipamiento médico crítico.
Escuela Armando López Sierra	• Plataforma LMS accesible durante horarios de clases. • Disponibilidad de bases de datos de estudiantes y contenidos digitales. • Acceso a laboratorios de informática en horarios programados.

Sector	Ejemplos
Finca La Costa	• Sistema de riego automatizado operativo durante la temporada de cultivo. • Disponibilidad de registros de inventario y producción. • Acceso constante a sensores de monitoreo agrícola.

3. Gestión de riesgos de la información

La gestión de riesgos de la información es un proceso sistemático mediante el cual la organización identifica, analiza, valora y controla los riesgos que pueden afectar sus activos de información. Su objetivo principal es proteger los activos de manera proporcional a su importancia y vulnerabilidad, ya que no es factible aplicar medidas a todos los activos de igual forma. Este enfoque permite priorizar los recursos, asegurar la continuidad operativa, garantizar la confiabilidad de la información y mantener la alineación con los objetivos estratégicos y la normativa vigente.

Gracias a este proceso, la organización puede:

- a)** Identificar amenazas y vulnerabilidades que puedan comprometer la confidencialidad, integridad y disponibilidad de los activos.
- b)** Evaluar el impacto potencial de incidentes sobre los procesos, recursos y reputación de la organización.
- c)** Definir controles y medidas de mitigación que reduzcan la probabilidad de ocurrencia o el efecto de los riesgos.
- d)** Optimizar la inversión en seguridad, priorizando los riesgos más críticos.

La gestión de riesgos de la información requiere priorizar los activos a proteger, debido a los costos, recursos y esfuerzos logísticos que implica su implementación. Por esta razón, muchas organizaciones se concentran primero en los activos más críticos. Además, a medida que la empresa es más grande y estructurada, cuenta con mayores capacidades para establecer un sistema integral de gestión de la información.

3.1 Criterios de identificación

La identificación de riesgos de la información es un procedimiento importante dentro de la gestión de la seguridad, al permitir reconocer o identificar las amenazas, vulnerabilidades y posibles impactos que puedan afectar o estén afectando los activos de la información en una organización. Por ejemplo, volviendo a una de las empresas con la que se ha venido trabajando para explicar mejor, se puede decir que la IPS ManoSana adquiere especial relevancia ya que maneja información sensible, relacionada con la salud de sus pacientes, lo cual exige criterios claros y aplicables para que se garanticen la confidencialidad, integridad y disponibilidad de los datos.

A continuación, se presenta una tabla que enseña más a profundidad como se pueden trabajar los principales criterios de identificación de riesgos, describiendo cada uno de ellos y fortaleciendo el tema con un ejemplo mediante situaciones simuladas adaptadas a la realidad de la empresa.

Tabla 7. Lista de criterios de identificación con descripción y ejemplos

Criterio	Descripción	Ejemplos en IPS ManoSana
Establecimiento del contexto	Definir el alcance, objetivos, criterios de riesgo y responsabilidad dentro de la organización.	La IPS define que el análisis de riesgos abarcará historias clínicas electrónicas, sistemas de citas y base de datos de pacientes, asignando la responsabilidad al área de TI y dirección médica.
Identificación de activos	Registrar todos los activos de información que la organización considera valiosos y críticos.	Se elabora un inventario con historias clínicas electrónicas, software de gestión hospitalaria, servidores, personal médico y contratos con aseguradoras.

Criterio	Descripción	Ejemplos en IPS ManoSana
Identificación de amenazas	Reconocer eventos o acciones (naturales, técnicas o humanas) que puedan afectar los activos.	Se identifican amenazas como ciberataques (ransomware), incendios en sala de servidores o errores humanos en actualización de datos de pacientes.
Identificación de vulnerabilidades	Detectar debilidades o faltas de control que los activos puedan tener frente a las amenazas.	Se evalúa la falta de doble autenticación en acceso a historias clínicas y la ausencia de copias de respaldo semanales como vulnerabilidades críticas.
Evaluación de probabilidad e impacto	Evaluar la probabilidad de que las amenazas se materialicen y el impacto que generarían.	Se estima la probabilidad media de phishing al personal administrativo y un impacto alto si ocurre, ya que comprometería datos sensibles de pacientes y la operación clínica.

3.2 Análisis de riesgos

El análisis de riesgos constituye la fase en la que se estudian con detalle las amenazas y vulnerabilidades identificadas previamente, con el fin de determinar su nivel de impacto y la probabilidad de ocurrencia. En una IPS como ManoSana. Este proceso permite priorizar los riesgos que afectan directamente la confidencialidad, integridad y disponibilidad de la información clínica de los pacientes, así como los procesos administrativos y financieros.

Para realizar el análisis, se deben considerar tres elementos importantes:

- **Probabilidad**

Medir la posibilidad de que un riesgo ocurra (alta, media o baja).

- **Impacto**

Valorar el efecto que tendría ese riesgo en la organización (operativo, legal, económico, reputacional).

- **Nivel de riesgo**

Combinación de probabilidad e impacto que define si el riesgo es aceptable, tolerable o requiere un tratamiento urgente.

En la IPS ManoSana, por ejemplo, un ataque de ransomware tendría una probabilidad media pero un impacto alto, ya que comprometería la disponibilidad de las historias clínicas y afectaría la atención a los pacientes. En cambio, la pérdida de un equipo obsoleto en bodega tendría una probabilidad alta pero un impacto bajo, siendo un riesgo de menor prioridad.

El análisis de riesgos se apoya en metodologías como ISO/IEC 27005 y en herramientas de matrices de impacto - probabilidad que facilitan la clasificación objetiva de los riesgos. Con base en este análisis, la IPS puede establecer estrategias de mitigación, transferencia o aceptación, optimizando los recursos disponibles y enfocándose en los riesgos más críticos.

Las estrategias que se pueden establecer son:

- **Mitigación**

Consiste en implementar controles o medidas preventivas para reducir la probabilidad de ocurrencia o el impacto de un riesgo.

Ejemplo: instalar un sistema de respaldo de datos para evitar pérdida de información.

- **Transferencia**

Implica trasladar el riesgo a un tercero, generalmente mediante seguros, contratos o servicios externos especializados.

Ejemplo: contratar un servicio en la nube con cláusulas de seguridad y respaldo.

- **Aceptación**

Se da cuando la organización reconoce el riesgo, pero decide no actuar porque su impacto es bajo o el costo de mitigarlo es mayor que el posible daño.

Ejemplo: aceptar fallos menores en un sistema no crítico.

3.3 Valoración y priorización de riesgos

Una vez identificados y clasificados los activos de información, es necesario asignarles un valor que permita establecer su nivel de importancia dentro de la organización. El proceso de valoración se realiza en pro de analizar el impacto que tendría la pérdida, alteración o indisponibilidad de los activos, lo que a su vez, afectaría la continuidad de las operaciones de la empresa, la reputación de su imagen y marca, y el cumplimiento de los objetivos estratégicos.

Es por ello, que se recomienda el empleo de una escala que combine aspectos valores cualitativos y cuantitativos, con el fin de brindar flexibilidad y se adapte a las características de cada empresa; de esta forma, se pueden asignar puntajes o categorías que definan la prioridad de un activo (alto, medio, bajo), tomando en cuenta parámetros como:

- **Confidencialidad**

Grado de sensibilidad de la información y las consecuencias de una divulgación sin autorización.

- **Integridad**

Importancia de mantener la exactitud y confiabilidad del activo.

- **Disponibilidad**

Necesidad de acceso oportuno para la operación normal de la empresa.

- **Impacto en el negocio**

Relación directa con procesos críticos, normativos o de servicio al cliente.

Teniendo en cuenta todos estos criterios, se puede llevar a cabo un ejercicio de priorización que ayude a valorar y ordenar los activos según su criticidad. El proceso de priorización podría variar en si se decide sumar o promediar los valores asignados a cada uno de los parámetros, aunque también se pueden desarrollar otro tipo de procedimientos, como por ejemplo, ponderaciones diferenciadas si un criterio es más importante que otro en la organización. También hay que considerar posibles variaciones en las escalas de valoración, lo que significa que cada empresa tendrá la autonomía de ajustar su modelo de medición, de acuerdo con el contexto en que se desenvuelve, ya sea implementando un enfoque más cuantitativo (midiendo en cifras) o cualitativo (valoración descriptiva).

De esta manera, y con el fin de evitar confusiones al clasificar los activos en las diferentes tipologías o categorías, es bueno tener una tabla de equivalencias que orienten la ubicación correcta de cada uno. Estas tablas de equivalencia podrían funcionar como guías de referencia que permiten mantener coherencia en la valoración

y evitar discrepancias cuando se trabaja con marcos conceptuales o normativos diferentes.

A continuación, se comparten unos pasos para construir una tabla de equivalencia:

1. Elegir una escala canónica

Se puede utilizar una escala del 1 al 5, donde 1 = muy bajo y 5 = muy alto.

2. Definir los criterios y su puntuación

Ejemplo: Confidencialidad (C), Integridad (I) y Disponibilidad (D), cada uno calificado de 1 a 5.

3. Normalizar los métodos

- Suma (C + I + D): valores entre 3 y 15 → convertir a escala 1 - 5 dividiendo entre 3. Fórmula: Equivalencia = $(C + I + D) / 3$.
- Promedio (C + I + D) / 3: ya estará en escala 1 - 5.

4. Definir umbrales canónicos para etiquetas cualitativas

- Alta: ≥ 4.33
- Media: 3.00 - 4.32
- Baja: ≤ 2.99

Ejemplo: suma 13 - 15 → Alta, porque $13/3 = 4.33$.

5. Registrar la equivalencia en una tabla

Se documenta la forma en que se pasa de un rango de suma a un rango en promedio y a su respectiva categoría cualitativa, asegurando así coherencia en la valoración, de tal manera que cualquier empresa pueda ajustarse fácilmente.

El uso de tablas de equivalencia o procesos de normalización es necesario cuando la organización trabaja con varios marcos o estándares (ISO 27001, NIST, COBIT, entre otros), ya que cada uno maneja escalas distintas de valoración. En cambio, si se adopta un único marco de referencia, no se requieren conversiones, pues ya existirá un lenguaje común y una escala definida en las políticas y procedimientos de la empresa.

Por medio de los ejemplos se ilustrará mejor el proceso de valoración de los activos, aplicando la simulación en las empresas con las que se ha venido trabajando:

Tabla 8. Valoración de activos en IPS ManoSana

Activo de información	C	I	D	Suma	Valoración global
Historia clínica digital (HCE).	5.	5.	4.	14.	Alta.
Servidor de BD clínicos.	5.	4.	5.	14.	Alta.
PACS (imágenes diagnósticas).	4.	5.	4.	13.	Alta.
Sistema de citas y admisiones.	3.	3.	4.	10.	Media.
Nómina y RR. HH. de la IPS.	4.	3.	3.	10.	Media.
Manual de inducción para personal nuevo.	2.	2.	2.	6.	Baja.

Tabla 9. Valoración de activos en Escuela Armando López Sierra

Activo de información	C	I	D	Suma	Valoración global
Base de datos de estudiantes.	5.	4.	4.	13.	Alta.
Sistema académico (notas y matrículas).	4.	5.	4.	13.	Alta.

Activo de información	C	I	D	Suma	Valoración global
Plataforma LMS (aulas virtuales).	3.	3.	5.	11.	Media.
Registros financieros institucionales.	4.	4.	3.	11.	Media.
Biblioteca digital y licencias.	2.	3.	4.	9.	Media.
Inventario de mobiliario escolar.	1.	2.	2.	5.	Baja.
Carteleras informativas físicas.	1.	2.	2.	9.	Baja.

Tabla 10. Valoración de activos en Finca La Costa

Activo de información	C	I	D	Suma	Valoración global
Información financiera y contable.	5.	4.	4.	13.	Alta.
Registro sanitario / vacunación del hato.	3.	4.	4.	11.	Media.
Sistema de riego automatizado.	2.	4.	5.	11.	Media.
Inventario de insumos y repuestos.	2.	3.	4.	9.	Media.
Registros de telemetría (drones / sensores).	2.	3.	3.	8.	Media.
Avisos publicitarios de la finca.	1.	2.	2.	5.	Baja.

En los ejemplos anteriores, para la valoración se tuvieron los siguientes parámetros:

C, I, A se valoran cuantitativamente (1 a 5).

Valor total se traduce a cualitativo según la suma:

12 – 15 = Alta.

8 – 11 = Media.

≤ 7 = Baja.

Para concluir, se presenta un ejemplo integrado en el que se muestra en una sola tabla tanto el registro como la valoración de los activos de información.

Tabla 11. Registro y valoración de activos en IPS ManoSana

ID	Activo	Tipo de Activo	Ubicación	Responsable	C	I	D	Valoración cuantitativa	Valoración cualitativa
1	Historia clínica electrónica.	Información.	Servidor central.	Jefe de sistemas.	5.	5.	5.	15.	Alta.
2	Servidor de base de datos.	Tecnológico.	Sala de servidores .	Administrador de TI.	5.	5.	4.	14.	Alta.
3	Red interna de comunicaciones.	Tecnológico.	Infraestructura IPS.	Coordinador de redes.	4.	4.	4.	12.	Alta.
4	Planta eléctrica.	Infraestructura física.	Patio IPS.	Jefe de mantenimiento.	3.	4.	4.	11.	Media.
5	Expedientes físicos (archivados) .	Información.	Archivo central.	Auxiliar administrativo.	4.	3.	4.	11.	Media.
6	Médicos especialistas.	Recursos humanos.	Consultorios.	Director médico.	5.	5.	5.	15.	Alta.

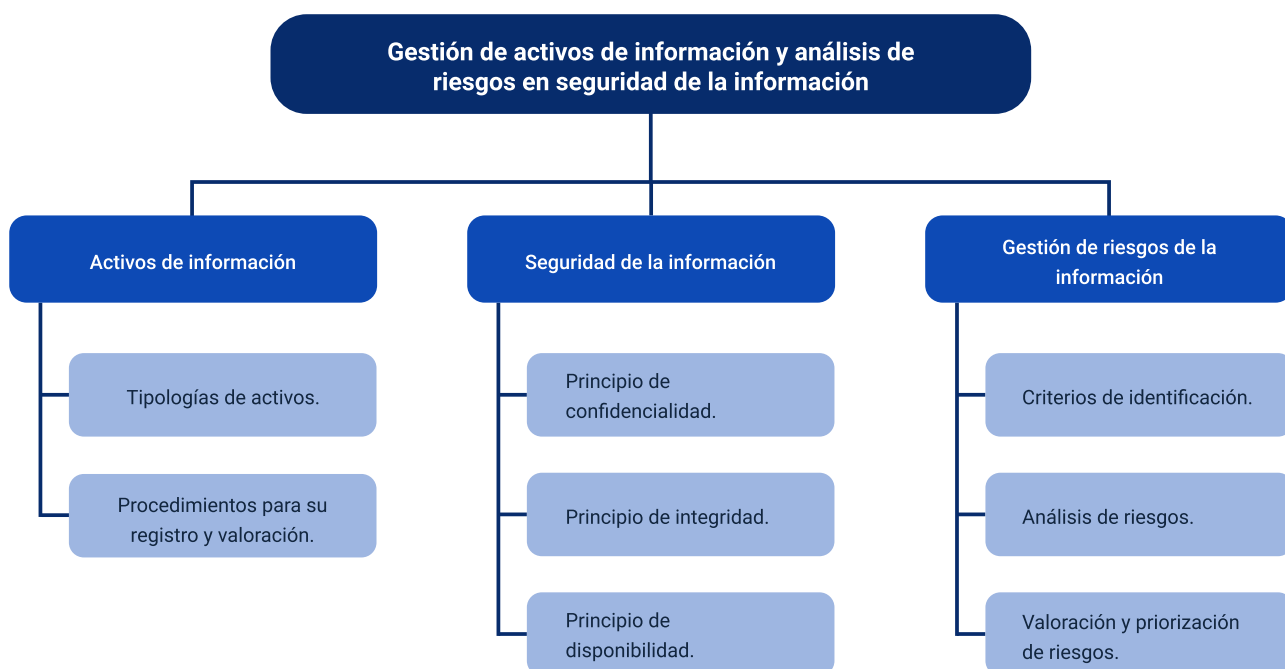
ID	Activo	Tipo de Activo	Ubicación	Responsable	C	I	D	Valoración cuantitativa	Valoración cualitativa
7	Políticas y protocolos clínicos.	Organizacional.	Dirección general.	Gerente IPS.	4.	4.	5.	13.	Alta.
8	Equipos de diagnóstico por imágenes.	Tecnológico.	Sala de radiología.	Jefe de radiología.	5.	4.	4.	13.	Alta.
9	Instalaciones físicas del edificio.	Infraestructura física.	Sede principal.	Área administrativa.	3.	3.	3.	9.	Media.
10	Personal de enfermería.	Recursos humanos.	Consultorios / UCI.	Coordinador de enfermería.	5.	4.	5.	14.	Alta.

Los activos de información representan el núcleo del funcionamiento de cualquier organización, pues incluyen tanto los datos críticos como los recursos tecnológicos, físicos, organizacionales y humanos que permiten cumplir con su misión. Reconocer su valor y tipología es fundamental para priorizar su protección y garantizar la continuidad operativa.

La seguridad de la información y la gestión de riesgos permiten identificar, analizar y valorar las amenazas que podrían afectar estos activos, estableciendo controles y medidas preventivas que minimicen impactos. De esta manera, las organizaciones aseguran confidencialidad, integridad y disponibilidad de su información, fortalecen su resiliencia y fomentan la confianza de sus usuarios, clientes y colaboradores, consolidando una gestión responsable y estratégica de sus recursos.

Síntesis

Se presenta la gestión de activos de información y el análisis de riesgos en seguridad de la información, organizada en tres áreas principales: los activos de información, la seguridad de la información y la gestión de riesgos. En el primer componente se incluyen las tipologías de activos y los procedimientos para su registro y valoración, los cuales permiten identificar y clasificar los recursos informativos de una organización. En el segundo componente se destacan los principios fundamentales de la seguridad de la información: confidencialidad, integridad y disponibilidad, que garantizan que los datos sean protegidos, se mantengan íntegros y estén disponibles cuando se requieran. Finalmente, la gestión de riesgos de la información aborda los criterios de identificación, el análisis de riesgos y la valoración y priorización de los mismos, con el fin de determinar las amenazas potenciales y establecer acciones adecuadas para su mitigación.



Material complementario

Tema	Referencia	Tipo de material	Enlace del recurso
Activos de información	DNP. (2023). Manual para la identificación de activos de información. DNP.	PDF	https://colaboracion.dnp.gov.co/CDT/DNP/SIG/M-PG-13%20Manual%20para%20la%20identificaci%C3%B3n%20de%20activos%20de%20informaci%C3%B3n.Pu.pdf
Activos de información	Ministerio de Tecnologías de la Información y las Comunicaciones - MINTIC. (2024). Registro de activos de información.	Página web	https://www.mintic.gov.co/portal/inicio/Atencion-y-Servicio-a-la-Ciudadania/Transparencia/135888:Registro-de-Activos-de-Informacion
Tipologías de activos	AND. (2020). Guía de gestión y clasificación de activos de información.	PDF	https://and.gov.co/sites/default/files/2022-05/Guia_De_Gestion_y_clasificacion_de_activos_de_informacion.pdf
Tipologías de activos	DIAN. (2023). Gestión de riesgos de seguridad de la información.	PDF	https://www.dian.gov.co/atencionciudadano/LMDP/Informacion-Innovacion-y-Tecnologia/Seguridad-de-la-Informacion/Cartillas/CT-IIT-0132.pdf

Tema	Referencia	Tipo de material	Enlace del recurso
Gestión de riesgos de la información	Global Quality Corp. (2022). ISO 27001: Gestión de riesgos de seguridad de la información en 3 minuto.	Vídeo	https://www.youtube.com/watch?v=1i-J3FtJYQg
Gestión de riesgos de la información	Tapiero, H., & Suárez, H. (2017). Modelo de gestión de riesgos de la seguridad de la información en empresas del sector asegurador utilizando la norma ISO/IEC 27005.	PDF	https://repository.udistrital.edu.co/server/api/core/bitstreams/dd0380aa-2a69-4f7b-a6a5-661a35229468/content
Gestión de riesgos de la información	Duque, G. (2023). Análisis de riesgo.	Vídeo	https://www.youtube.com/watch?v=GOiHOCBJxmM

Glosario

Activos de información: elementos que poseen valor para una organización, como datos, software, hardware, personas o servicios. Identificarlos y clasificarlos es fundamental para su protección dentro del sistema de seguridad.

Análisis de riesgo: es el proceso sistemático de identificar amenazas y vulnerabilidades que pueden afectar los activos de información. Incluye la evaluación de la probabilidad de ocurrencia y el impacto potencial, proporcionando información clave para tomar decisiones sobre medidas de mitigación.

CIA (Confidencialidad, Integridad, Disponibilidad): principios fundamentales de la seguridad de la información que aseguran que los datos sean accesibles solo por personas autorizadas, no sean alterados indebidamente y estén disponibles cuando se necesiten.

Controles de seguridad: son las medidas, técnicas, administrativas y físicas implementadas para proteger los activos de información. Su objetivo es prevenir incidentes, detectar irregularidades y mitigar impactos, asegurando la confidencialidad, integridad y disponibilidad de los datos.

Gestión de riesgos: conjunto de procesos que permite identificar, analizar, valorar, tratar y monitorear riesgos, con el fin de minimizar su impacto en la seguridad de la información y los objetivos organizacionales.

Normativa: conjunto de leyes, estándares técnicos y buenas prácticas que orientan a las organizaciones en el diseño, implementación y cumplimiento de políticas de seguridad de la información.

Prioridad de activos: es la clasificación de los activos de información según su importancia o criticidad para la organización. Permite enfocar los esfuerzos de protección y asignar recursos de manera eficiente, garantizando que los activos más críticos reciban la atención necesaria para su resguardo.

Riesgo: posibilidad de que una amenaza aproveche una vulnerabilidad para causar daño a los activos de información, afectando la confidencialidad, integridad o disponibilidad de los mismos. Su análisis permite tomar decisiones informadas.

Seguridad de la información: disciplina que implementa medidas para proteger los datos de una organización, garantizando que se mantengan confidenciales, íntegros y disponibles ante cualquier tipo de amenaza.

Valoración de riesgo: consiste en asignar un nivel de importancia o gravedad a los riesgos identificados, considerando su probabilidad y el impacto que tendrían sobre los activos. Esta valoración facilita priorizar acciones preventivas o correctivas para minimizar los efectos negativos sobre la organización.

Referencias bibliográficas

AND. (2020a). Guía de gestión y clasificación de activos de información.

https://and.gov.co/sites/default/files/2022-05/Guia_De_Gestion_y_clasificacion_de_activos_de_informacon.pdf

AND. (2020b). Guía de gestión y clasificación de activos de información.

https://and.gov.co/sites/default/files/2022-05/Guia_De_Gestion_y_clasificacion_de_activos_de_informacon.pdf

Cane, T. (2025). ISO 27001:2022 annex A 5.9 – inventory of information and other associated assets. ISMS.Online. <https://www.isms.online/iso-27001/annex-a/5-9-inventory-of-information-other-associated-assets-2022/>

Ministerio de hacienda y administraciones públicas. (2012). MAGERIT - versión 3.0.

<https://es.slideshare.net/slideshow/magerit-v3-libro2catalogo-de-elementosesnipo630121718/128115305>

MINTIC. (2025). Registro de Activos de Información.

<https://mintic.gov.co/portal/inicio/Atencion-y-Servicio-a-la-Ciudadania/Transparencia/135888:Registro-de-Activos-de-Informacion>

Mohan, V. (2024). ISO 27001 Annex A.8: Asset management explained. Sprinto.

<https://sprinto.com/blog/iso-27001-annex-a-8-asset-management/>

Novaseguridad. (2021). La seguridad de la información y sus 3 pilares fundamentales.

Novasep. <https://www.novaseguridad.com.co/seguridad-de-la-informacion-principios/>

Créditos

Nombre	Cargo	Centro de Formación y Regional
Milady Tatiana Villamil Castellanos	Responsable del ecosistema	Dirección General
Claudia Johanna Gómez Pérez	Responsable de línea de producción	Centro Agroturístico - Regional Santander
Armando Javier López Sierra	Experto temático	Centro de Comercio y Servicios - Regional Tolima.
Erika Fernanda Mejía Pinzón	Evaluadora para contenidos inclusivos y accesibles	Centro Agroturístico - Regional Santander
Yuly Andrea Rey Quiñonez	Diseñadora de contenidos	Centro Agroturístico - Regional Santander
Lillibeth Liseth Celis Pardo	Desarrolladora full stack junior	Centro Agroturístico - Regional Santander
Johann Sebastián Teran Carvajal	Animador y productor audiovisual	Centro Agroturístico - Regional Santander
Andrea Ardila Chaparro	Evaluadora para contenidos inclusivos y accesibles	Centro Agroturístico - Regional Santander